PRODUCT REQUIREMENTS AND GO-TO-MARKET BRIEF

ai-taint-path

An intelligence-led prioritization layer that finds the AI agents and MCP servers a company runs and ranks the attack paths that lead through them to its crown jewels.

Yaron Shumunov · November 2026 · Demo and code at yaronimac.github.io/ai-taint-path

Problem	Security teams see thousands of exposures and cannot tell which few reach their critical assets. AI agents add a fast-growing class of exposures that their tools do not model at all.
Buyer	The CISO or head of exposure management at a 1,000 to 10,000-employee company rolling out AI agents.
Route to market	MSSP and MDR partners first, with a free open-source edition.
Positioning	A layer on top of the scanners and CTEM tools a customer already owns, which makes them agent-aware.
Pricing	Per protected asset, with each AI agent, MCP server and RAG knowledge base counted as an asset.
Status	Discovery, ranking, the dashboard and JSON output are built and shown on a sample company. The analyst agent and the rest of the SOAR integration are next.

Problem and opportunity

Security teams can see thousands of exposures but can't tell which few actually lead to their critical assets, and AI agents are now adding a fast-growing class of exposures that their tools don't model at all.

- **Prioritization is broken.** 97% of security teams struggle to know which exposures are actually exploitable, 42% of analyst time goes to risks that turn out not to matter, and 84% of SOC teams were hit through risks they already knew about (Filigran survey, vendor-run).
- **AI agents are a new, unmanaged attack surface.** 38% of 560 scanned MCP servers had no authentication, 30 MCP vulnerabilities were filed in 60 days, and only 21% of executives have full visibility into what their agents can access (DEV roundup).

- **Analysts agree it's the priority.** Two of Gartner's six top cybersecurity trends for 2026 are oversight of AI agents and adapting identity management to them (Gartner).

Why now: agent adoption is moving from pilots to production, while dedicated MCP security startups have raised only about $40M (Software Strategies). Exposure tools that already sit in the budget have no agent-aware prioritization yet, which leaves room for a layer that adds it.

Users and buyers

The CISO buys it, the exposure management lead uses it daily, and engineers act on what it produces. The MSSP is the channel that brings it to many CISOs at once.

PERSONA	ROLE IN THE DEAL	JOB TO BE DONE	WHAT THEY NEED FROM THE PRODUCT
CISO	Economic buyer	Show the board that exposure is falling while the company rolls out AI	A one-page board brief with a trend and three asks
Head of exposure management	Champion and daily user	Fix the 10 things that matter this week, not 10,000 findings	Ranked attack paths, each with a plain-language reason
Cloud or IT engineer	Remediation owner	Know exactly what to change and why it's urgent	A ready-to-file ticket with the fix and the evidence
AI platform owner	Influencer	Ship agents without them becoming the breach path	An inventory of agents and MCP servers with risky permissions flagged
MSSP service manager	Channel partner	Deliver CTEM to many clients with a small team	Repeatable, brandable reports per client (after the MVP)

Product decisions

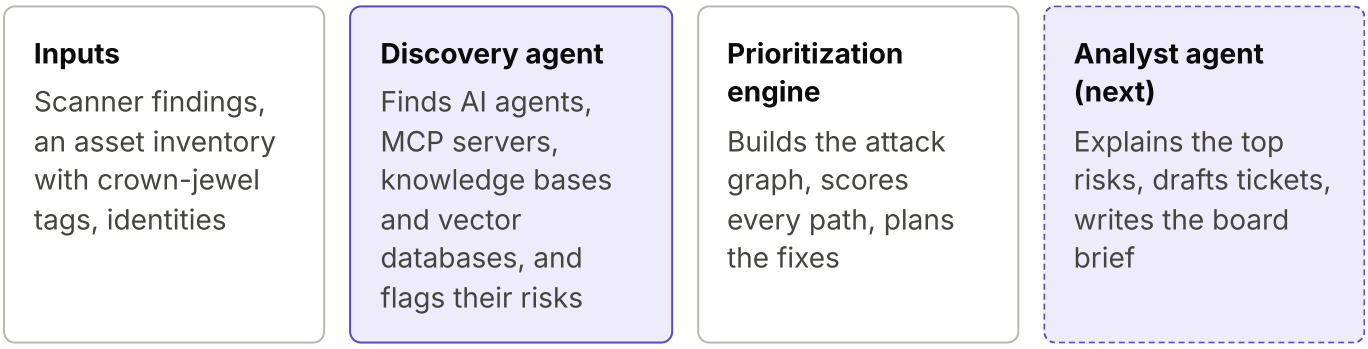
Six calls shape everything else in this brief.

DECISION	CHOICE	WHY
Primary buyer	Enterprise CISO or head of exposure management at a 1,000 to 10,000-employee company rolling out AI agents	Owns the budget and the board conversation
Route to market	MSSP and MDR partners first, with a free open-source edition for credibility	One partner brings the product to many CISOs, and practitioners can check an open-source edition for themselves

Positioning	A layer on top: it imports findings from existing scanners and CTEM tools and makes them agent-aware	Buyers are consolidating vendors, not adding platforms
Pricing model	Per protected asset, with each AI agent, MCP server and RAG knowledge base counted as an asset	Matches how exposure tools are already bought, and grows with agent adoption
What the MVP produces	A discovered agent and MCP inventory, the top 10 ranked attack paths, remediation tickets and a one-page board brief, all also delivered as JSON and through a REST API with webhooks for SOAR	Every persona gets something to act on: the engineer a ticket, the exposure lead a ranked list, the CISO a brief
Name	ai-taint-path	From taint analysis: it follows untrusted input (a chat message, an emailed invoice, a poisoned document) through agents, tools and identities to a crown jewel

MVP scope

The MVP runs two agents on one fictional company: a discovery agent that finds its AI agents and MCP servers and checks how risky they are, and an analyst agent that turns everything into a top-10 list of attack paths, tickets and a board brief. It uses only free data sources.



Discovery feeds the engine the AI attack surface that scanners don't see. The analyst agent only explains scores the engine computed.

IN THE MVP	WHAT IT DOES	STATUS
Inputs	Scanner findings, an asset inventory with crown-jewel tags, and identities, as JSON files. The AI agent and MCP inventory is not hand-written: the discovery agent builds it.	Built
Discovery agent	Finds AI agents, MCP servers and RAG pipelines (vector databases and the knowledge bases agents retrieve from) from three sources: MCP config files on laptops and servers (Claude, Cursor, VS Code), read-only probes of MCP and vector database endpoints on an approved scope list, and exported cloud AI inventories (AWS Bedrock agents and knowledge bases, Azure AI Foundry, Azure AI Search). It flags missing authentication, high-risk tools (shell, payments, external email), vulnerable MCP packages such as mcp-remote and MCP Inspector, tool descriptions with hidden instructions, vector stores open without login, knowledge bases fed from untrusted sources, and retrieval that ignores document permissions. Each finding maps to the OWASP agentic and LLM risks and MITRE ATLAS.	Built

Enrichment	CISA KEV (exploited in the wild), FIRST EPSS (likelihood of exploitation), MITRE ATT&CK techniques, the OWASP Top 10 for Agentic Applications for agent risks, and the OWASP Top 10 for LLM Applications for RAG risks.	Built
Attack paths	A graph from internet-facing entry points to crown-jewel assets, where agents, knowledge bases and machine identities are nodes that can be abused along the way.	Built
Explainable score	Every path gets a score and the reasons for it, in words a CISO can read.	Built
Web dashboard	The ranked paths, each in technical detail, the fix plan and the AI inventory, as one self-contained page.	Built
Analyst agent	A Claude agent that explains the top risks, drafts remediation tickets and writes the board brief.	Next
MCP server	Lets other AI assistants ask the product questions.	Next

SOAR integration

Every output is machine-readable, so security automation can act on it without a person in the loop.

INTERFACE	WHAT IT DOES	STATUS
JSON output	`scan --format json` writes the inventory, findings and ranked paths as JSON with a published, versioned JSON Schema	Built
REST API	Start a scan, list ranked paths, get a path's evidence and ticket. An OpenAPI spec is generated automatically	Next
Webhook	Pushes each new or worsened critical path to a SOAR endpoint as JSON, signed so the receiver can verify it	Next
Example playbook	One working playbook (Cortex XSOAR generic webhook or a Microsoft Sentinel Logic App) that opens a case per critical path and assigns the ticket owner	Next
Integration guide	Field-by-field schema reference, example payloads and setup steps for the playbook, in the repo docs	Next

Not in the MVP: live vulnerability scanning, live cloud API discovery (the MVP reads exported inventories), probing anything outside the approved scope list, calling MCP tools (discovery only lists them), live connectors to scanners and CTEM tools, multiple clients (tenants), user accounts, and automatic fixes.

Core user stories

1. As an AI platform owner, I want the discovery agent to find every AI agent, MCP server and RAG knowledge base in use, including ones nobody registered, so shadow AI shows up in the inventory. Built

2. As an AI platform owner, I want each discovered MCP server checked for missing login, high-risk tools and known-vulnerable packages, so I can fix them before an attacker finds them. Built
3. As an AI platform owner, I want every knowledge base mapped to the sources that feed it and the agents that read it, so a poisoned document or an open vector store shows up as an attack path. Built
4. As a head of exposure management, I want the 10 attack paths that reach crown-jewel assets, ranked, so my team works on what matters first. Built
5. As a head of exposure management, I want each path's reason in plain words, so I can defend the ranking to engineers and auditors. Built
6. As a cloud engineer, I want a ready-to-file ticket with the fix and evidence, so I can act without a meeting. Next
7. As a SOAR engineer at a company or MSSP, I want new critical paths pushed to my SOAR as JSON, so playbooks open cases and route fixes automatically. Next
8. As a CISO, I want a one-page brief showing the trend and three asks, so I can take it straight to the board. Next

---

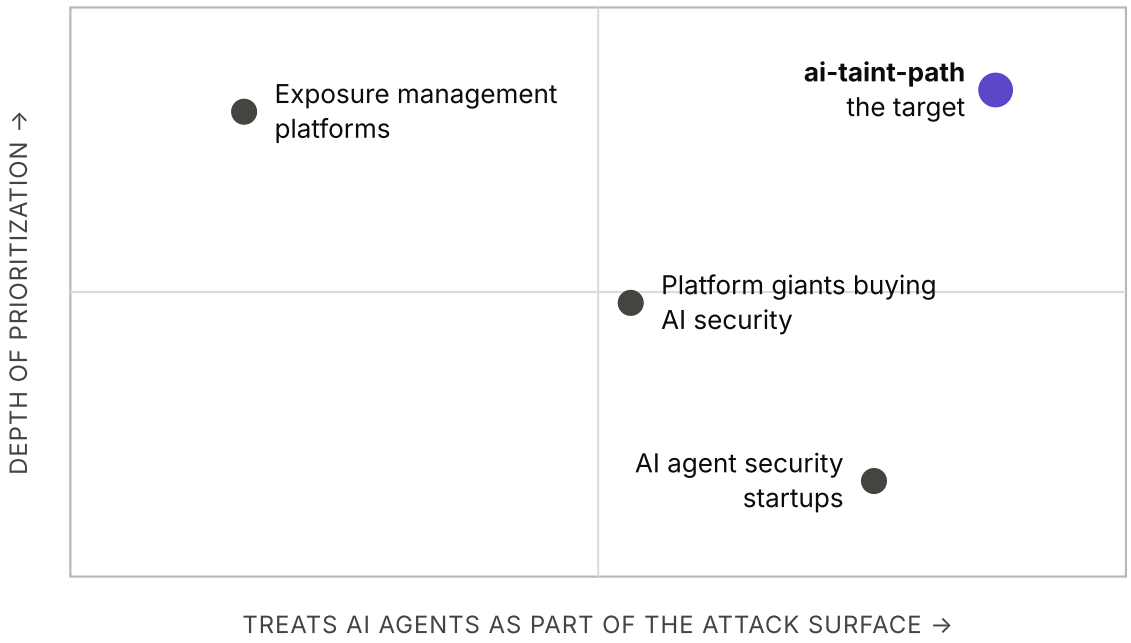
What the build shows so far

The demo runs on Halden Logistics, a fictional 4,500-person freight company with real CVEs and planted problems. The numbers below come from the published scan result, which the test suite regenerates and compares on every run.

- The exposure index is 433.4 of 600 with AI discovery, against 245.7 on scanner, CMDB and posture data alone.
- 7 of the top 10 attack paths run through AI components. 4 of them are invisible without discovery, and 3 more score far lower without it.
- Discovery finds 19 AI components, 8 of them in no inventory, and raises 25 risk flags, 7 of them critical.
- 5 fixes cut the exposure index by 78.7%. The first is a VPN flaw that ranks only 11th on a list sorted by CVSS, and 2 of the 5 are agent approval settings that no vulnerability scanner reports.
- 8 of the 10 highest-CVSS findings lead to no crown jewel at all.

Competitive landscape

Exposure platforms are strong at prioritization but treat AI agents as an add-on, while AI agent security startups find agents but don't rank them against the rest of the attack surface. The gap is joining the two, and the closest player doing so today is Wiz, but only for cloud.



A qualitative map. The top-right corner is the target: deep prioritization that treats agents as part of the attack surface, across cloud and on-premises.

SEGMENT	EXAMPLES	THEIR STRENGTH	THEIR GAP	OUR ANGLE
Exposure management platforms	Tenable One, XM Cyber, Microsoft Security Exposure Management, Trend Micro Vision One (list)	Broad asset coverage, attack paths, established budgets	AI agents and MCP servers are new add-on modules, not part of the core path model	Import their findings and add agent-aware paths on top, rather than compete
AI agent security startups	Noma ($132M raised), Zenity ($125M Series C)	Deep agent discovery, access policies, runtime monitoring	Agent risk sits in its own console, not ranked against the rest of the attack surface	Discover agents and MCP servers too, then put their risk in the same ranked list as everything else
Platform giants buying AI security	Palo Alto (Protect AI), Check Point (Lakera), Google (Wiz) (deals)	Distribution and bundling power	Integration takes years, and bundles favour their own stack	Vendor-neutral, works across Microsoft, Palo Alto and others

Incumbents are adding AI coverage quickly, so the honest pitch is a sharper, intelligence-led prioritization layer that also works through MSSPs. It is not a claim that nobody else covers agents.

Positioning, packaging and pricing

Position it as the prioritization layer that makes existing exposure tools agent-aware, sell it through MSSPs, and price it per protected asset with agents counted as assets.

Positioning statement. For CISOs at enterprises rolling out AI agents, who can't tell which of thousands of exposures reach their crown jewels, this product is an intelligence-led prioritization layer. It discovers the AI agents and MCP servers in use, ranks attack paths across infrastructure, identities and those agents, then turns them into tickets and a board brief. Unlike exposure platforms that bolt on AI modules, or agent security tools in a separate console, it puts agent risk in the same ranked list, on top of the tools you already own.

Three messages

- Fix the 10 paths that reach your crown jewels, not 10,000 findings.
- Find the AI agents, MCP servers and RAG knowledge bases you didn't know you had, and see their risk in the same list as everything else.
- From raw findings to a board-ready brief in minutes.

Packaging hypothesis

EDITION	WHO IT'S FOR	WHAT'S INCLUDED
Community (open source)	Practitioners and evaluators	Discovery agent, file import, ranking, dashboard, JSON output, REST API and webhooks, AI explanations with your own API key
Professional	Enterprise exposure management teams	Connectors to major scanners and CTEM tools, scheduled runs, Jira and ServiceNow tickets, packaged SOAR playbooks
MSSP	MSSP and MDR providers	Multiple clients, brandable board briefs, per-client billing

Pricing hypothesis: an annual price per protected asset, with each AI agent, MCP server and RAG knowledge base counted as an asset, so revenue grows with the customer's agent adoption. MSSPs get volume tiers per client. Price points are an open question, to be tested with design partners.

Go-to-market motion: launch the open-source edition with a case study, recruit three MSSP design partners for the MSSP edition, then list on the AWS and Azure marketplaces.

Success metrics and risks

The MVP succeeds if it reliably surfaces the paths that matter, explains each one, and gets from raw files to a board brief in minutes. Targets are set on the sample company and checked by automated tests.

METRIC	MVP TARGET	HOW IT'S MEASURED	STATUS
Discovery coverage	Finds every planted agent, MCP server and knowledge base, including one shadow server missing from all inventories	Test suite on the sample company	Met

Discovery accuracy	Flags every planted unauthenticated server, open vector store, vulnerable MCP package, poisoned tool description and poisoned knowledge-base document, with no false alarms on the clean ones	Test suite on the sample company	**Met**
Ranking quality	Every planted critical path (known-exploited flaw or agent misconfiguration reaching a crown jewel) lands in the top 10	Test suite on the sample company	**Met**
Explainability	Every ranked path explains itself and maps to ATT&CK, ATLAS or OWASP	Automated check: every hop carries a one-sentence reason, and every cited framework entry is verified	**Met**
SOAR integration	Every new critical path reaches the example playbook by webhook and opens a case, and all JSON validates against the published schema	Integration test and recorded demo	**Schema met, webhook next**
Time to brief	Discovery to board brief in under 5 minutes	Timed demo run	**Next**

RISK	MITIGATION
It looks like a toy	A realistic fictional company and real public threat data (KEV, EPSS, ATT&CK)
The AI gets facts wrong	Scores are computed by code. The AI only explains them and must cite the evidence
Discovery probing looks like an attack	Probes only hosts on an explicit scope list, and only asks a server to describe itself. It never calls a tool
A poisoned tool description manipulates the discovery agent	Tool descriptions are treated as untrusted data, checked by rules first, and never followed as instructions
Scope creep	The MVP list above is fixed. Everything else goes to a backlog in the repo
Confidentiality	No real employer or client data. The company and its findings are invented
API costs on the public demo	The hosted demo is a pre-generated page and calls no model

Sources

- Filigran: State of Threat Management 2026 (vendor survey)
- DEV: 30 CVEs in 60 days, MCP's security reckoning
- Gartner: Top Cybersecurity Trends for 2026
- Software Strategies Blog: agentic AI security funding and M&A
- OWASP Top 10 for Agentic Applications
- CISA Known Exploited Vulnerabilities catalog
- Tenable: Leader in Gartner Magic Quadrant for Exposure Assessment Platforms
- IT Security Guru: Exposure assessment platforms to watch in 2026
- Noma Security vendor profile
- Zenity Series C

Halden Logistics is fictional. No real company's data is used. © 2026 Yaron Shumunov.